

ASSIGNMENT

Ethical Hacking & Web Application Security

Total Questions: 20

Instructions

- Answer all 20 questions.
- Use diagrams, tables, screenshots, and practical examples wherever appropriate.
- For practical activities, use only authorized lab environments such as DVWA, Metasploitable, or intentionally vulnerable applications.
- Mention the tools/commands used and explain the observations.

Unit I – Foundations of Ethical Hacking

1. Define ethical hacking. Explain the difference between White Hat, Black Hat, and Grey Hat hackers with suitable examples.
2. Explain the CIA Triad in cybersecurity. How do Confidentiality, Integrity, and Availability apply to an organization's security?
3. Explain the five phases of ethical hacking: Reconnaissance, Scanning & Enumeration, Gaining Access, Maintaining Access, and Clearing Tracks.
4. Explain the concept of vulnerability assessment and penetration testing (VAPT). Differentiate between vulnerability assessment and penetration testing.

Unit II – Reconnaissance, Scanning & Enumeration

5. What is passive reconnaissance? Explain how Google Dorking can be used to identify publicly available information about a target.
6. Explain WHOIS, nslookup, and dig. What type of information can be obtained using each tool?
7. Perform passive reconnaissance on an authorized domain using theHarvester, WHOIS, nslookup, and dig. Document the domains, subdomains, IP addresses, DNS records, mail servers, and other relevant information identified.
8. What is active reconnaissance? Explain how Nmap can be used to identify open ports, running services, service versions, and operating-system information.
9. Perform an Nmap scan against an authorized lab target. Identify the open ports, services, service versions, and OS information. Present your findings in a structured table.

Unit III – System Exploitation & Post-Exploitation

10. Explain the Metasploit Framework architecture. Describe the purpose of exploits, payloads, encoders, auxiliary modules, and post-exploitation modules.
11. Explain the difference between bind shell and reverse shell. Discuss situations in which each type of shell may be used in a controlled penetration-testing environment.
12. What is privilege escalation? Explain the difference between vertical and horizontal privilege escalation with suitable examples.

13. Explain persistence in post-exploitation. Discuss common persistence concepts and why persistence should be detected and removed during incident response.

Unit IV – Web Application Penetration Testing

14. Explain the OWASP Top 10. Describe any five vulnerabilities from the OWASP Top 10 and provide a brief example of each.

15. Using DVWA, demonstrate a Brute Force vulnerability using Hydra in an authorized lab environment. Explain the vulnerability, observations, and security controls that can prevent brute-force attacks.

16. Using DVWA and Burp Suite, demonstrate how an intercepted HTTP request can be analyzed and modified. Explain the purpose of Proxy, Repeater, and Intruder in Burp Suite.

17. Using DVWA, investigate SQL Injection. Explain how user input can affect a database query, identify the vulnerability, and discuss appropriate mitigation techniques such as parameterized queries.

18. Using DVWA, investigate OS Command Injection. Demonstrate the issue using a harmless command in the isolated lab and explain the root cause, impact, and mitigation.

19. Explain Cross-Site Scripting (XSS) and its types: Reflected XSS, Stored XSS, and DOM-based XSS. Also explain how input validation and output encoding help prevent XSS.

Unit V – VAPT Reporting

20. Prepare a professional VAPT report for an authorized vulnerable application. The report should contain:

- Executive Summary
- Scope and Methodology
- Tools Used
- Vulnerabilities Identified
- Technical Findings
- Evidence/Screenshots
- CVSS Score
- Business Impact
- Remediation Recommendations
- Conclusion

Suggested Practical Platforms

- DVWA
- Metasploitable
- OWASP Juice Shop
- Other intentionally vulnerable lab environments